

5 Steps to Close the AI Security Gap in Your Cloud Strategy



LLMs have created significant blind spots for cloud security. This guide provides a structured, five-step approach to identify, assess, and mitigate AI-specific security risks by leveraging the unified code-to-cloud-to-SOC capabilities of Cortex Cloud.

Main Topics

- Introduction 3
- Building Blocks and Security Implications of Modern, AI-Powered Applications . . 4
- Why Your Security Program Might Need a Version Update 6
- 5 Steps to Close the AI Security Gap 8



Introduction

An AI-Generated Security Problem

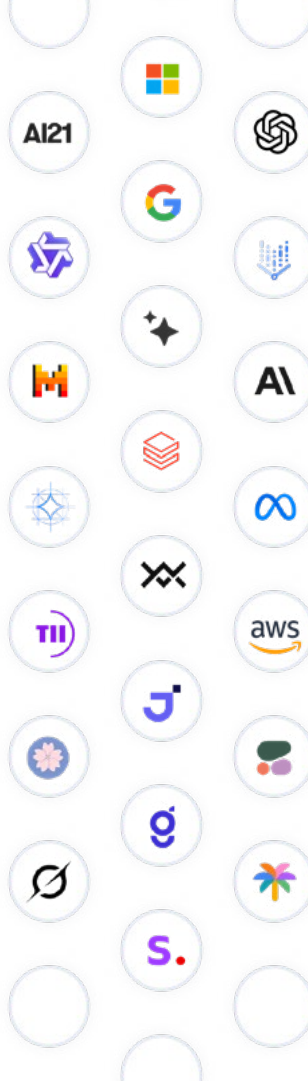
When it comes to AI, most security teams are still figuring out where to start. New LLMs and other AI infrastructure have popped up across IT environments in recent years. More recently, AI agents and semi-autonomous workflows have added yet another layer of complexity and unpredictability. With change coming fast and furious, there's a growing disconnect between existing security practices and what's needed to secure these new technologies.

You're not alone if you're asking questions like:

- Which specific AI assets or models actually need my attention?
- Do my existing CSPM, DSPM, and CNAPP tools cover new risks?
- Which policies need updating?
- Where should I even begin?

AI isn't the first technology shift to which security teams have had to adapt quickly. With that said, the current generation of AI tooling comes with its own unique characteristics. Some are related to the unprecedented scope and pace in which these tools are being adopted; others are due to their reliance on large volumes of data, the common model-as-an-API-endpoint deployment mode, and the "black box" nature of trained models. Regardless, all these characteristics pose distinct challenges for traditional security frameworks, processes, and tools.

In this e-book, we look at the gaps that AI-powered applications create in the current security stack. We then outline a five-step strategy to incorporate AI into your broader cloud security initiatives, built around Cortex Cloud AI Security Posture Management (AI-SPM), Data Security Posture Management (DSPM), near-real-time Data Detection and Response (DDR), and code-to-cloud-to-SOC capabilities.



Building Blocks and Security Implications of Modern, AI-Powered Applications

Let's start with a basic review of the technologies behind AI. We will focus on LLMs rather than on "traditional" AI or machine learning models, as the latter two are less novel from a security perspective and typically not the focal point of current industry discussions.

Large Language Models (LLMs)

LLMs are sophisticated neural networks trained on vast text datasets in order to understand and generate human-like text. In practice, this makes them suited for a wide array of tasks – from software development to creative writing. Your organization might use them through third-

party APIs like OpenAI's GPT-4, managed cloud services like Amazon Bedrock, or the deployment of open-source models on your infrastructure.

Use case example: An LLM-powered copilot or chatbot is added to help users gain more value from your application (e.g., a CRM tool that adds another tool to generate email copy).

Security implications

- Exposure of sensitive data contained in training or inference datasets
- Risk of "model poisoning" attacks
- Vulnerabilities and backdoors in open-source/open-weight models
- Prompt injections used to manipulate the LLM into insecure or unsafe responses
- Use of unsanctioned models or unauthorized use of sanctioned models (e.g., for sensitive use cases)

Retrieval Augmented Generation (RAG)

RAG improves LLM output by connecting base models to external data sources. Instead of relying solely on knowledge encoded in their parameters, the models use relevant information from other data stores to provide more accurate or context-rich responses. RAG pipelines will often convert enterprise data into vector embeddings stored in specialized databases and then feed relevant information to the LLM as additional context.

Use case example: A RAG-enabled assistant responds to product questions by retrieving information from your current product catalog and support knowledge base.

Security implications

- New exposure points for sensitive data when user-facing LLMs are exposed to internal data, with potentially more third-party tools involved in the data supply chain
- Data poisoning, where misleading or dangerous data is injected into inference datasets to reduce model accuracy or to create unsafe behaviors
- Commonly-used vector databases that may lack expected security controls

AI Agents

AI agents are typically used to describe AI-powered systems that combine multiple LLMs and API integrations to perform actions, make decisions, and use leverage tools. These agents can call APIs, access databases, and execute multi-step tasks with minimal human intervention.

Use case example: A finance department deploys an agent to review quarterly reports, generate financial analyses, and email its findings to relevant stakeholders.

Security implications

- Creation of a non-human identity comparable to a human actor, in terms of security overhead, since agents often require a broad set of permissions for diverse internal and external systems
- Need for a different approach to security compared to traditional IT systems due to non-deterministic output and behavior
- Heightened risk of LLM-focused attacks such as prompt injection due to potential downstream implications on other systems

Why Your Security Program Might Need a Version Update

Strategic Side of Things

Now that we have a high-level understanding of how modern AI-powered applications are built, we can start looking at how they impact the way you handle cloud security.

Beyond the specific security implications of each separate element, as discussed previously, the ways in which new LLM tools are deployed – and their rapid adoption in the enterprise – can create strategic holes in your security program and render certain processes and tools unfit for use.

The AI security gap can manifest in four main ways.

1. Old problems that return with a vengeance

In certain cases, AI will not create a new category of problems as much as it will amplify existing challenges. Let's take the example of data access controls. If an LLM is trained on your customer database, it can memorize sensitive information and reproduce it during inference months later – long after the initial access has been removed. Similarly, AI agents can create an explosion of non-human identities (beyond what's already happening today), further complicating data access governance.

2. Need for new categories of control for AI models

Your existing security monitoring wasn't designed for AI models, which require entirely different types of oversight. For example, this could include tracking model provenance and lineage to prevent supply chain attacks, monitoring training



data for bias or poisoning attempts, implementing guardrails against prompt injection, detecting unauthorized model training, and continuously evaluating model outputs for safety violations or data leakage. The required controls will often cross organizational boundaries among data science teams, platform engineers, legal and compliance personnel, and security professionals.

3. Skill and tool gaps

Security teams are tasked with the unenviable responsibility of building AI security expertise while trying to secure AI implementations, which is not trivial even for the most senior and technical professionals. And the abundance of disconnected point solutions for individual AI risks isn't helping: When one tool monitors model access, another checks prompt security, and a third handles data lineage, critical relationships can go undetected.

4. Emerging compliance mandates

New compliance frameworks and industry standards are creating requirements that your existing compliance program wasn't designed to address. For example, NIST AI 600-1 requires specific documentation of training data sources, while the OWASP Top 10 for LLM Applications highlights AI-specific vulnerabilities like training data poisoning and prompt injection, which don't map cleanly to traditional vulnerability management categories. The EU AI Act, set to come into force in 2026, will raise the bar even higher, with strict and binding rules related to AI usage and governance alongside strong enforcement mechanisms (including significant financial sanctions).

It's worth noting that every problem described above is compounded when LLMs move from stand-alone components to agentic workflows, which give models unprecedented power to

access and manipulate other systems in your environment. Agents add another layer of opacity and non-determinism to what's actually going on, since you end up dealing with dozens or hundreds of "black box" decisions all at once. Add to that the broad set of permissions they require, and you find yourself with an exponentially larger pool of attack paths to consider.

In the following sections, we'll explore a practical, integrated way to address these interconnected challenges.

5 Steps to Close the AI Security Gap

We've seen how AI creates blind spots in your security strategy. Now let's talk about what you can actually do about it. The following five-step approach gives you a practical framework to systematically adapt your cloud security to the realities of modern AI-powered applications.

Each step builds on the previous one. Instead of using separate tools, our approach is built on integrating AI security into your broader security program – ensuring you don't miss important connections between data, AI, and cloud resources.

Step 1

AI Model, Data and Identity Visibility

Step 2

Posture Analysis and Prioritization

Step 3

Compliance Monitoring

Step 4

Monitoring, Detection, and Response

Step 5

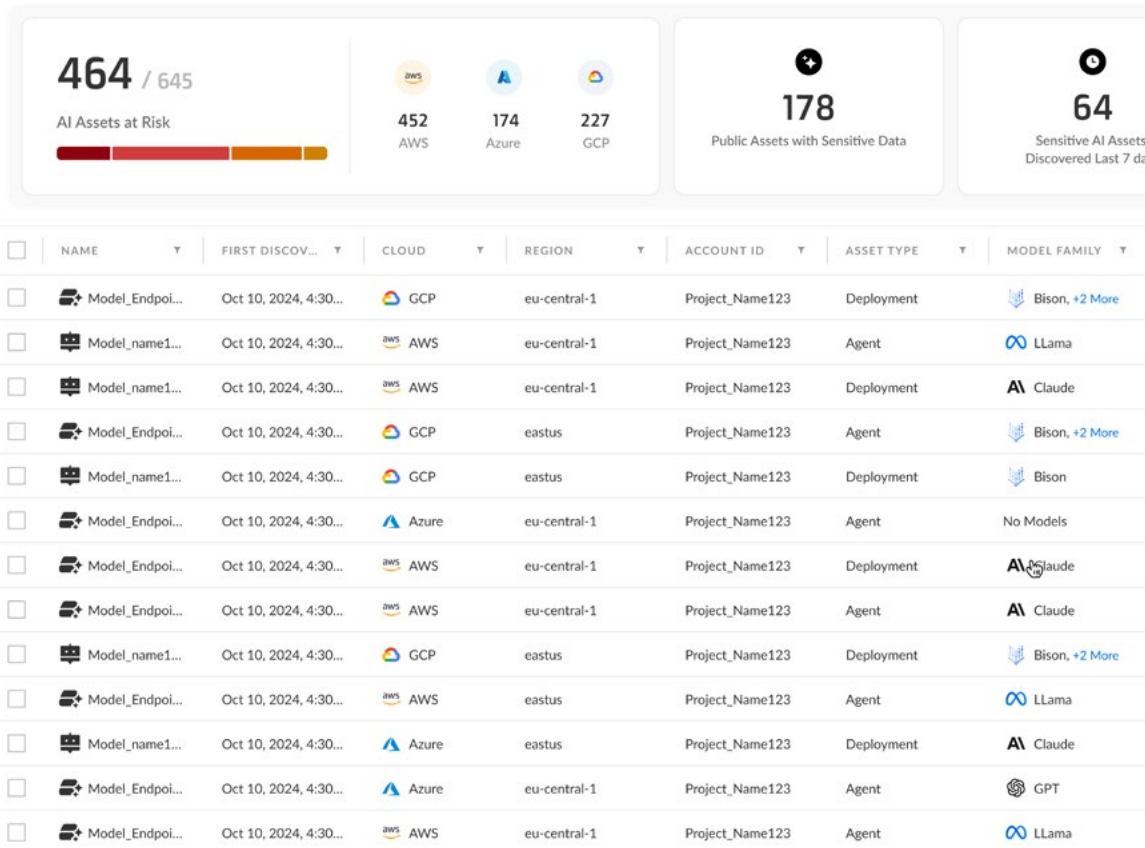
Cloud and AI Security Integration

Step 1

AI Model, Data and Identity Visibility

Every security strategy starts with visibility. You can't secure what you can't see – and with AI, there's a lot more to see than meets the eye. AI deployments introduce a new layer on top of your existing cloud infrastructure: If your security tools show your cloud resources and data stores but fail to highlight model interactions, they're not giving you the full picture.

For example, your data security tools might show a vector database and associated cloud storage, while missing the fact that these data assets are being accessed by both legitimate LLM applications and an unauthorized AI agent with excessive permissions. Without this context, significant risks remain invisible. Similarly, a model deployed on a VM might appear as just another workload to your CSPM tools, which would fail to account for its unique access patterns and higher risk profile. Was it trained on sensitive customer data? Is it exposed to the internet without proper guardrails?



As such, effective AI visibility requires the collaboration of two dimensions.

1. Cloud and data visibility

You need to be able to see your data storage, access permissions, networks, and cloud resources. This baseline understanding remains essential even as your environment evolves. With Cortex Cloud, this starts with the Cloud Security Command Center, which gives you a bird's-eye view of your cloud environment.

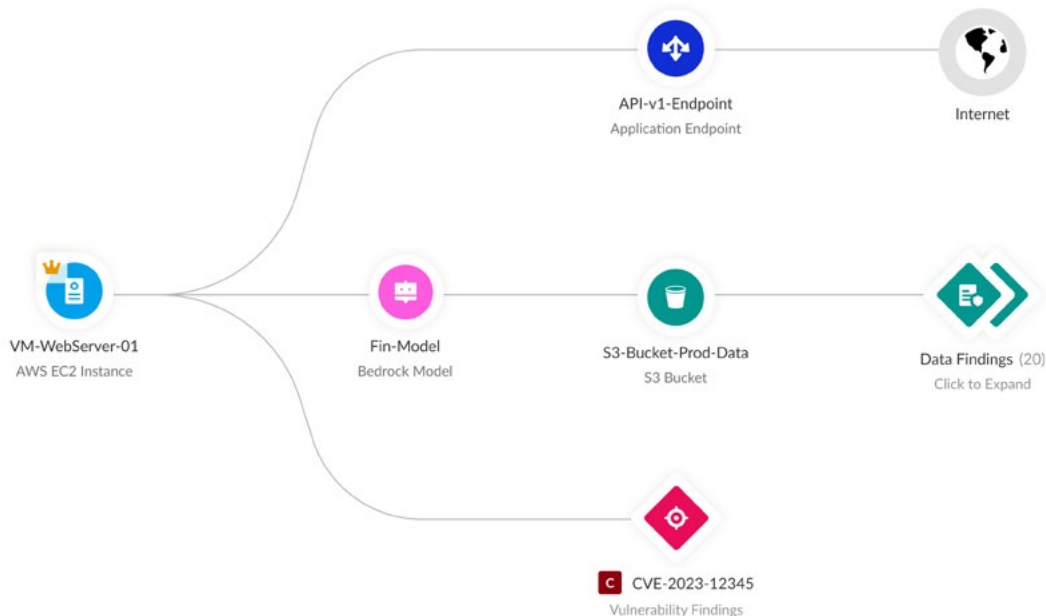
2. AI inventory

You need to know which models are deployed, where inference endpoints exist, what AI-powered applications are running, and how data flows between them. This includes tracking both homegrown and third-party models across your environment.

With Cortex Cloud, your AI inventory is available out of the box, enabling you to see more than just models, including their endpoints, clouds on which they're

being deployed, models running on virtual machines, and AI-dependent code found in your repositories.

You can also use graph search to better understand complex, multi-cloud environments.



Step 2

Posture Analysis and Prioritization

Now that you can see what's happening in your environment, it's time to determine what these findings mean for your security.

Posture Analysis

Posture analysis looks at how different systems interact to create exploitable attack paths, and helps you understand which problems you need to tackle first based on their potential impact on your organization.

AI posture analysis covers three connected areas.

1. Sensitive data

Identifying and classifying sensitive information, such as personally identifiable information (PII), financial records, or intellectual property, and mapping relevant storage locations and data flows.



Top AI Issues to Address

Remediate the most pressing issues to improve your AI security posture. [Show all issues](#)

Model poisoning risk on fine-tuned model trained on a publicly writable dataset

First discovered on May 5, 2025, 9:01 AM

Fine-tuned model was trained on a publicly accessible dataset

First discovered on May 5, 2025, 9:01 AM

Fine-tuned model was trained on a publicly accessible dataset

First discovered on May 5, 2025, 9:01 AM

Storage asset with LLM prompt history is publicly accessible

First discovered on May 5, 2025, 9:01 AM

Sensitive AI model endpoint is publicly accessible

First discovered on May 5, 2025, 9:01 AM

2. Exposure pathways

Identifying unique exposure pathways such as an LLM that could inadvertently memorize customer credit card numbers during training, or a misconfigured vector database that could expose proprietary information through RAG implementations.

3. AI-specific risk

Analyzing unique risks that go beyond data concerns, such as supply chain issues with open-source models, data poisoning vulnerabilities, or inadequate guardrails against harmful outputs.

Prioritization

Most teams struggle with prioritizing thousands of alerts in order to focus on the few that matter. Consider a situation where role-based permissions have been granted to a production LLM without enabled guardrails that's connected to an embeddings database containing customer financial data. Each individual issue might seem

minor, but all of them together create a serious vulnerability. Prioritizing risks effectively means seeing these connections and understanding how combinations of model, data, and access risks consolidate into exploitable attack paths.

Attack path analysis that accounts for the entire application context can help teams prioritize the most pertinent issue rather than chase isolated alerts. With Cortex Cloud, this can be achieved by using built-in prioritization capabilities as well as custom rules and policies – for example, identifying when a model is not being used in ways that have been approved by company policies.

Finally, you can close the loop with built-in remediation. By selecting an issue, you can immediately launch the relevant playbook, enabling SOC teams to investigate and mitigate high-priority problems in a timely manner.

Sensitive Data Used by AI

Monitor and mitigate AI usage of sensitive information



Step 3

Compliance Monitoring

The AI compliance landscape has expanded significantly in recent years, adding new requirements beyond traditional data protection regulations and industry standards. While traditional regulations such as GDPR and standards such as SOC 2 are still relevant for AI-powered applications, recently established AI-specific frameworks require different priorities and controls.

Two such frameworks that have been widely adopted are:

OWASP Top 10 for LLM Applications identifies security risks specific to LLMs, including prompt injection attacks, excessive agency, improper output handling, and unbounded consumption.

NIST AI 600-1 (AI Risk Management Framework) offers a structured system for AI governance throughout the life cycle, with requirements for documenting training data

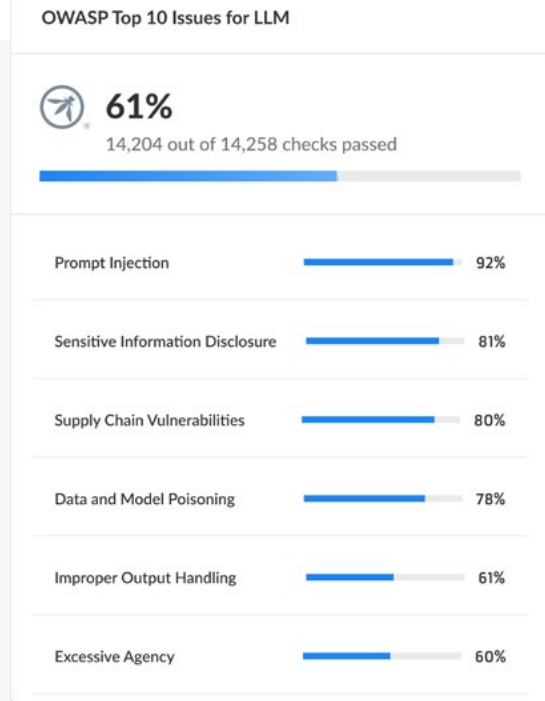
sources and monitoring deployment outcomes.

You should first determine which frameworks matter to your specific business context: Not every standard needs equal attention, as requirements vary by industry and use case.

Once you've identified the relevant frameworks, map your controls to their requirements. The visibility from your inventory work in Step 1 becomes valuable here. For example, documenting training data sources is straightforward when you already have a complete model inventory and can see associated data storage.

Cortex Cloud helps security and GRC teams understand their current compliance posture and find ways to improve it.

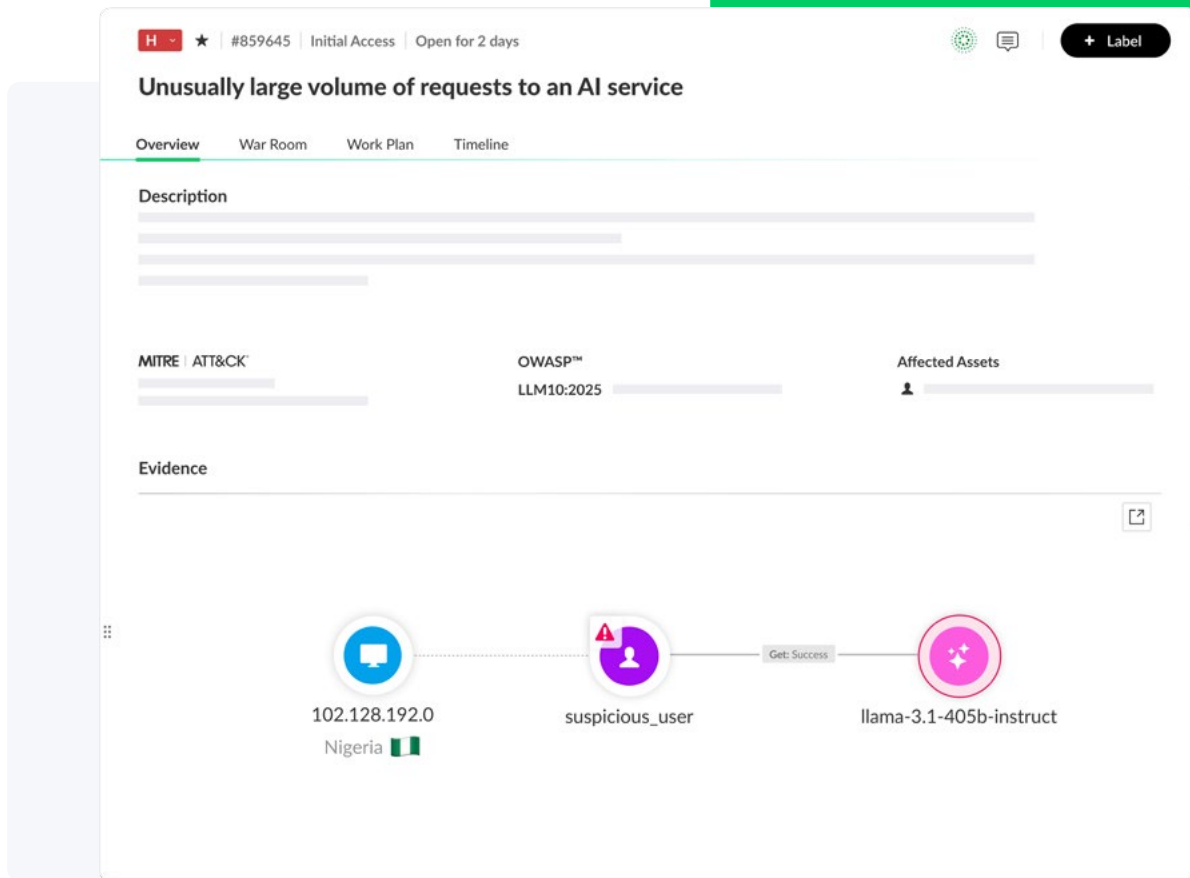
The unified platform approach is helpful here as well. It can surface changes to your environment that impact your compliance posture, and help identify gaps between your controls and framework expectations – such as deploying a new language model that might trigger new requirements.



Step 4

Monitoring, Detection, and Response

Real-time security adds an active defensive layer for AI applications, including those already in production. Unlike traditional software that follows deterministic execution paths, AI-powered tools can behave unpredictably based on the inputs they receive, making real-time monitoring an important part of the mix.



What to Monitor in Real Time

- **Data access** – Tracking who or what is accessing your sensitive data and AI assets, and alerting on unusual patterns that may indicate compromise (data detection and response – DDR)
- **New model deployments** – Scanning cloud environments for changes in deployed models to detect unsanctioned models, especially ones with known security risks
- **Prompts and outputs** – Examining inputs and responses for signs of manipulation or data leakage
- **Model behavior** – Spotting unexpected model or agent behavior that might indicate tampering

Cortex Cloud provides real-time security through cloud detection and response capabilities, which help monitor interactions between data, applications, and models, as well

as surface high-priority risks in real time when they occur.

Response and Remediation

When incidents happen, security teams need AI-specific guidance. Should you take the model offline? Should you restrict data access? Integrated remediation reduces room for error, and creates further assurance that response actions will trigger as expected.

Cortex Cloud enables you to trigger the relevant remediation playbook in response to a specific risk. You can do so either manually or through powerful automation capabilities, which build on the classifications, risks, and findings generated in your posture analysis.

Top AI Assets at Risk

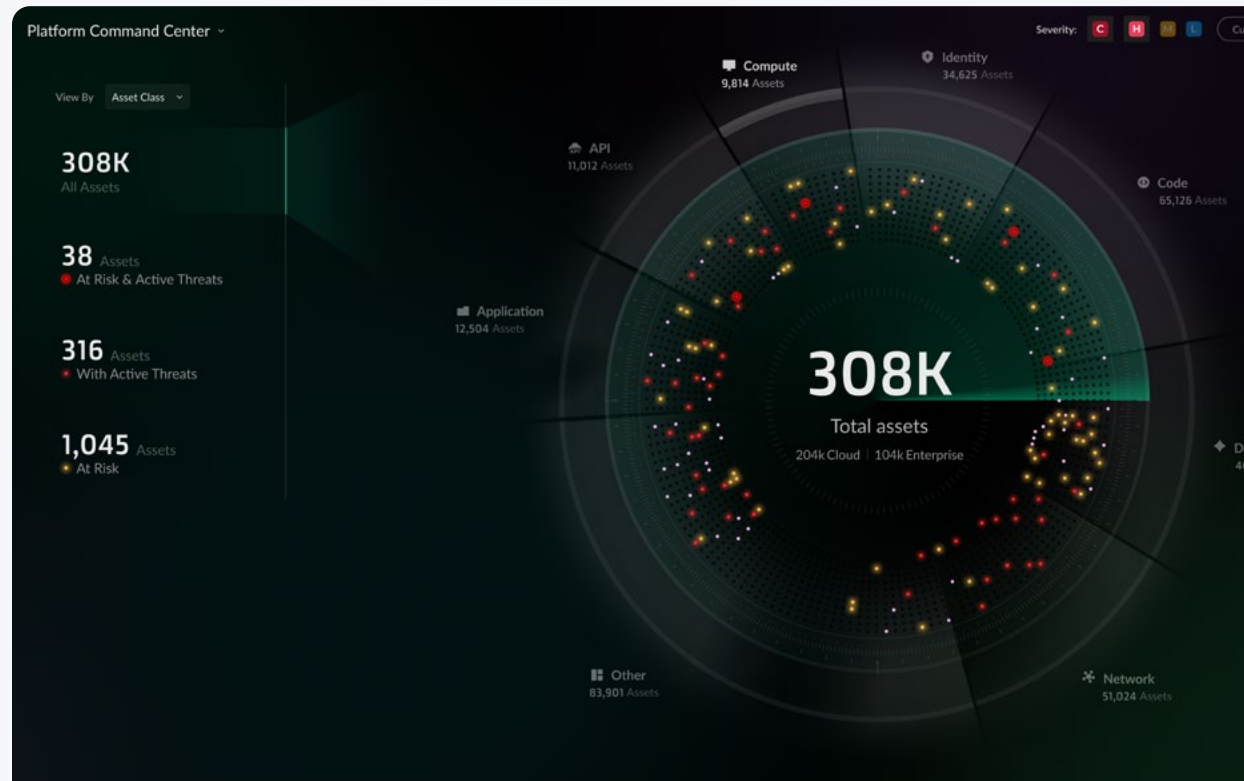
	bedrock-custom-gptx-2025 Bedrock Custom Model	 132  233
	openai-gpt4-turbo-prod Open AI Deployment	 131  230
	rds-prod-user-data RDS Database Instance	 99  198
	nlp-finetuned-bedrock-v1 Bedrock Custom Model	 47  179
	openai-chatbot-v2-deploy Open AI Deployment	 145
	customer-db-rds-primary RDS Database Instance	 128
	openai-summarization-service Open AI Deployment	 89

Step 5

Cloud and AI Security Integration

AI security should never exist in isolation. When it's treated as a separate problem from your overall cloud security strategy, important context is lost. For example, a publicly-accessible VM might not seem like a major issue, but it becomes so if that machine is running an open-source model trained on your codebase.

The most effective security programs layer business and application context on top of technical telemetry. This means understanding not only that an LLM exists in your environment, but also how it's being used across your business. Is it powering



a customer-facing tool? Receiving data from the web? Automating employee workflows? Each use case carries different risk profiles and requires different security controls.

The platform approach of Cortex Cloud enables you to see this bigger picture as well as drill down into specific aspects of cloud and AI security. It offers several benefits in this regard when compared to using an assortment of point solutions and built-in patches.

Fewer blind spots and silos. When one tool sees cloud resources but not models, another sees models but not data, and a third sees data but not infrastructure, critical risk connections are missed. A unified view shows the complete attack path.

Less alert fatigue by correlating signals across your environment. Rather than receiving separate alerts about open S3

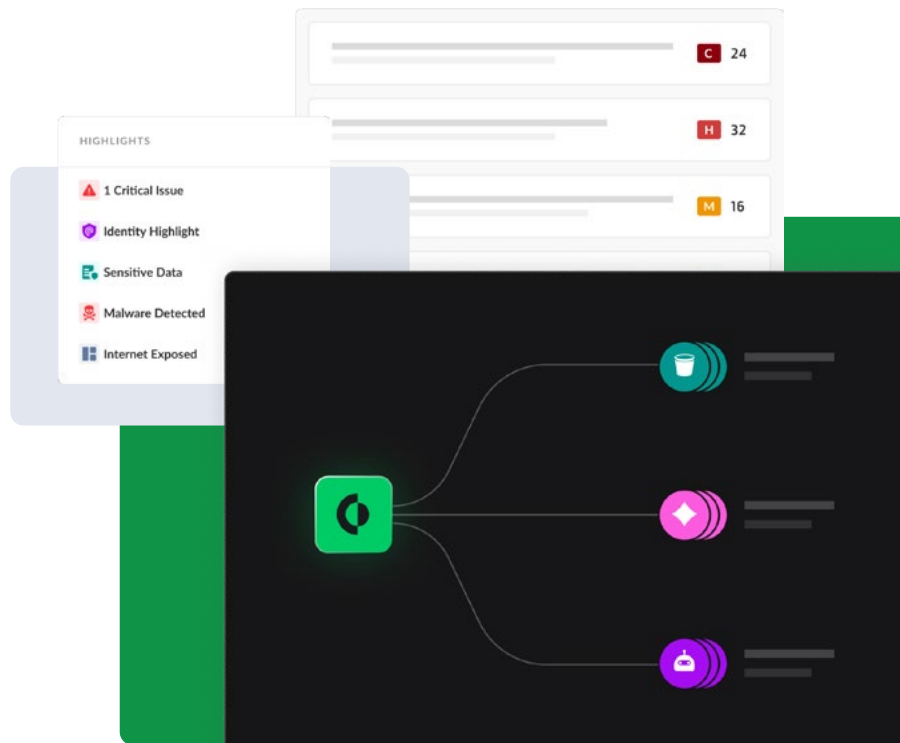
buckets, excessive model permissions, and sensitive data classification, you see one high-priority issue. For example: "AI model with public internet access can read customer financial data."

Faster remediation due to integration. When your security team uncovers an AI-related vulnerability, it needs to work closely with data engineers, cloud teams, and application developers. A shared platform with consistent workflows accelerates this process and eliminates much tedium and coordination overhead.

Learn More About Code to Cloud to SOC Security with Palo Alto Networks

Cortex Cloud™ unites the world's leading CNAPP with the #1 SecOps platform to deliver real-time security from Code to Cloud to SOC. Break down silos and gain complete risk context to operate with confidence and unmatched efficiency. Together, unified data, AI, and automation power an adaptive defense that stops threats at their source. Investigate and respond in minutes, remediate in seconds with Cortex Cloud™.

Learn more at <https://www.paloaltonetworks.com/cortex/cortex-cloud>



3000 Tannery Way
Santa Clara, CA 95054

Main: +1.408.753.4000
Sales: +1.866.320.4788
Support: +1.866.898.9087
www.paloaltonetworks.com

© 2025 Palo Alto Networks, Inc. A list of our trademarks in the United States and other jurisdictions can be found at <https://www.paloaltonetworks.com/company/trademarks.html>. All other marks mentioned herein may be trademarks of their respective companies.

cortex_eb_5 Steps to Close the AI Security Gap_5.25